🔒 PENETRATION TESTING REPORT

Client: demo.testfire

Target: https://demo.testfire.net

Generated: 3/13/2026, 5:01:48 AM

Classification: CONFIDENTIAL

DOCUMENT INFORMATION

Report Type	Evidence-Based Security Assessment
Target	https://demo.testfire.net
Assessment Date	2026-03-13
Generated By	VulnCraft AI

1. EXECUTIVE SUMMARY

1.1 Assessment Overview

The assessment of https://demo.testfire.net revealed multiple medium-severity vulnerabilities, indicating areas for improvement in the application's security posture.

1.2 Key Observations

The observed behaviors suggest a need for enhanced security configurations and header management to mitigate potential risks.

2. ASSESSMENT CONTEXT

Target Application: https://demo.testfire.net

Assessment Type: Black Box

Assessment Nature: Automated testing with evidence-based review

Methodology Reference: OWASP Testing Guide, PTES

3. OBSERVED SECURITY FINDINGS

V-001 - COOKIE SECURITY FLAGS

Finding ID: V-001

Severity Level: Medium

Evidence Confidence: Medium

OBSERVATION SUMMARY

Indicators suggest that the application's cookies lack appropriate security flags, potentially exposing user session data.

WHY THIS MATTERS

This vulnerability could allow unauthorized access to user sessions, compromising data confidentiality and integrity.

TECHNICAL EVIDENCE

Endpoint: https://demo.testfire.net

HTTP Method: GET

Parameter: N/A

Payload Tested: N/A

Observed Response or Behavior: See raw scan output

V-002 - INFO DISCLOSURE HEADERS

Finding ID: V-002

Severity Level: Medium

Evidence Confidence: Medium

OBSERVATION SUMMARY

Observed behavior indicates that the application discloses sensitive information through its headers, potentially aiding attackers in reconnaissance efforts.

WHY THIS MATTERS

This vulnerability could facilitate attacks by providing valuable information about the application's infrastructure and technologies used.

TECHNICAL EVIDENCE

Endpoint: https://demo.testfire.net

HTTP Method: GET

Parameter: N/A

Payload Tested: N/A

Observed Response or Behavior: See raw scan output

V-003 - MISSING SECURITY HEADERS

Finding ID: V-003

Severity Level: Medium

Evidence Confidence: Medium

OBSERVATION SUMMARY

Indicators suggest that the application is missing essential security headers, which could leave it vulnerable to various web attacks.

WHY THIS MATTERS

The absence of these headers could facilitate cross-site scripting (XSS), clickjacking, and other types of attacks, compromising user data and application integrity.

TECHNICAL EVIDENCE

Endpoint: https://demo.testfire.net

HTTP Method: GET

Parameter: N/A

Payload Tested: N/A

Observed Response or Behavior: See raw scan output

V-004 - PERMISSIONS POLICY

Finding ID: V-004

Severity Level: Medium

Evidence Confidence: Medium

OBSERVATION SUMMARY

Observed behavior indicates that the application's permissions policy may not be adequately configured, potentially leading to over-permissive access to sensitive features.

WHY THIS MATTERS

This could result in unauthorized access to application features, compromising data security and potentially leading to malicious activities.

TECHNICAL EVIDENCE

Endpoint: https://demo.testfire.net

HTTP Method: GET

Parameter: N/A

Payload Tested: N/A

Observed Response or Behavior: See raw scan output

4. FINDINGS SUMMARY

ID	Title	Severity	Evidence Confidence
V-001	COOKIE SECURITY FLAGS	Medium	Medium
V-002	INFO DISCLOSURE HEADERS	Medium	Medium
V-003	MISSING SECURITY HEADERS	Medium	Medium
V-004	PERMISSIONS POLICY	Medium	Medium

5. REMEDIATION & VALIDATION GUIDANCE

V-001 - COOKIE SECURITY FLAGS

Implement secure cookie flags to protect user session data. Ensure that all cookies are properly configured with the 'Secure' and 'HttpOnly' flags.

V-002 - INFO DISCLOSURE HEADERS

Configure the application to remove or obscure sensitive information from its headers. Implement a Content Security Policy (CSP) to define allowed sources of content.

V-003 - MISSING SECURITY HEADERS

Implement all necessary security headers, including but not limited to 'Content-Security-Policy', 'X-Frame-Options', and 'X-Content-Type-Options', to protect against web-based attacks.

V-004 - PERMISSIONS POLICY

Review and refine the permissions policy to ensure that it adheres to the principle of least privilege. Restrict access to sensitive features and data based on user roles and requirements.

6. OVERALL ASSESSMENT VERDICT

Based on the observed findings, it is recommended that the identified vulnerabilities be addressed through the implementation of secure coding practices, enhanced security configurations, and regular security audits to ensure the application's security posture is maintained. Manual validation and thorough testing should be performed to confirm the effectiveness of the remediation efforts. Continuous monitoring and periodic assessments are crucial for identifying and mitigating emerging security threats.

7. TECHNICAL APPENDIX

V-001 - COOKIE SECURITY FLAGS

Finding ID: V-001

Endpoint(s): https://demo.testfire.net

Parameter(s): N/A

Payload(s) tested: N/A

Observed response patterns: See raw scan output

V-002 - INFO DISCLOSURE HEADERS

Finding ID: V-002

Endpoint(s): https://demo.testfire.net

Parameter(s): N/A

Payload(s) tested: N/A

Observed response patterns: See raw scan output

V-003 - MISSING SECURITY HEADERS

Finding ID: V-003

Endpoint(s): https://demo.testfire.net

Parameter(s): N/A

Payload(s) tested: N/A

Observed response patterns: See raw scan output

V-004 - PERMISSIONS POLICY

Finding ID: V-004

Endpoint(s): https://demo.testfire.net

Parameter(s): N/A

Payload(s) tested: N/A

Observed response patterns: See raw scan output

END OF REPORT

VulnCraft – Security Assessment Project CONFIDENTIAL